Storebrand

Detection Engineering and Purple Teaming

Sikkerhetsanalytikerkonferansen

11.03.2026

whoami.x64.o

- Lead Detection Engineer at Storebrand Cyber Defence Center
  - Storebrand, SPP, Delphi Funds, Skagen
- Detection Engineering and Purple Team SME
- Reformed Red Teamer
- Conducted and lead international red team engagements and TIBER
- 14 years in IT, ranging from support, sys and network admin to RT/PT and now DEATH
- ~~5H3LLCAST~~
- Dad, bushcraft/survival, FPV and MTG "enthusiast"
- DEATHCon, HackCon, Sikkerhetsfestivalen, BSides KRS, NFCERT Annual Conference(s)
- Whole bunch of certs, courses and trainings
  - CARTP, CRTE, CRTO, Adv Threat Emulation BH'21, Adversary Tactics: Detection, Red Team Operations, Attacking and Defending Azure & M365, Constructing Defense, SANS SEC699 +

README GPL-2.0 license

Situational Awareness BOF

This repo intends to serve two purposes. First it provides a nice set of basic situational awareness commands implemented in a Beacon Object File (BOF). This allows you to perform some checks on a host before you begin executing commands that may be more invasive.

Its larger goal is providing a code example and workflow for others to begin making more BOFs. It is a companion document of the blog post made here: https://www.trustedsec.com/blog/a-developers-introduction-to-beacon-object-files/

Anders Olaus Granerud · 1st 1mo
Teammanager TIBER-NO

Love 1 Reply 1

Eirik Sveen Author 1mo
Lead Detection Engineer at Storebrand

Anders Olaus Granerud

Like 1 Reply

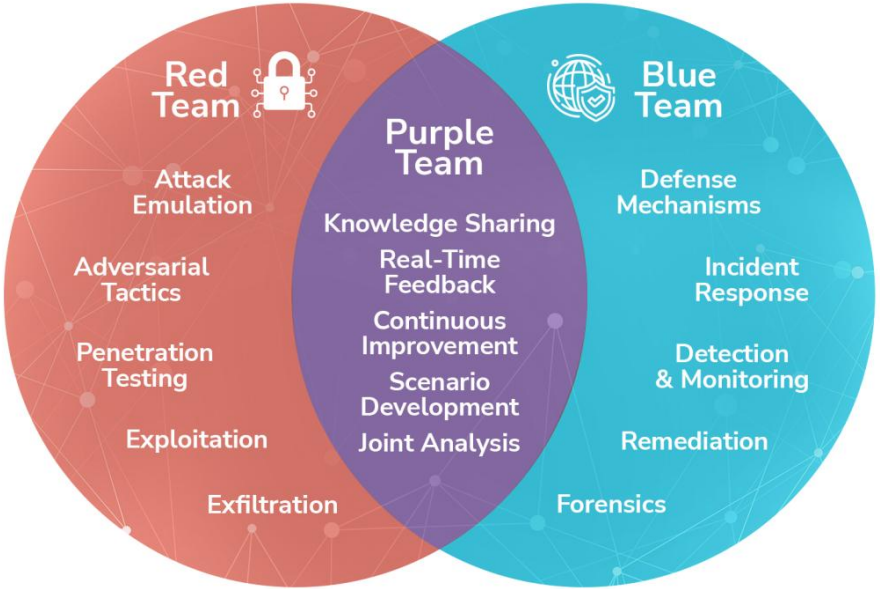
What is Purple Teaming?

- "The continuous collaboration between various cybersecurity skill sets to test, measure, and improve resilience to cybersecurity threats and attacks."
- **Collaborative**, **transparent** threat emulation to measure **detection** and **response**
  - **Testing people, process and technology**
  - **Learning and continuous improvement over stealth and realism**
- The two most common methodologies
  - **Scenario based** (end to end chains -> time to detect/contain, "how far did we get before an alert was triggered?", "how long did it take/would it take to realistically act on the alert, if at all?")
  - **Atomic** ("a single irreducible unit or component in a larger system", single techniques -> fast coverage checks, clean regression baselines)
    - Overlaps with telemetry generation and rule validation in Detection Engineering
- Typical focus areas
  - Emulate current and relevant TTPs based on TI, observed initial access techniques, phishing kits, test OST and adversary behaviors against **your stack**

Purple Team Exercise Framework (PTEF)

Why should you do Purple Teaming?

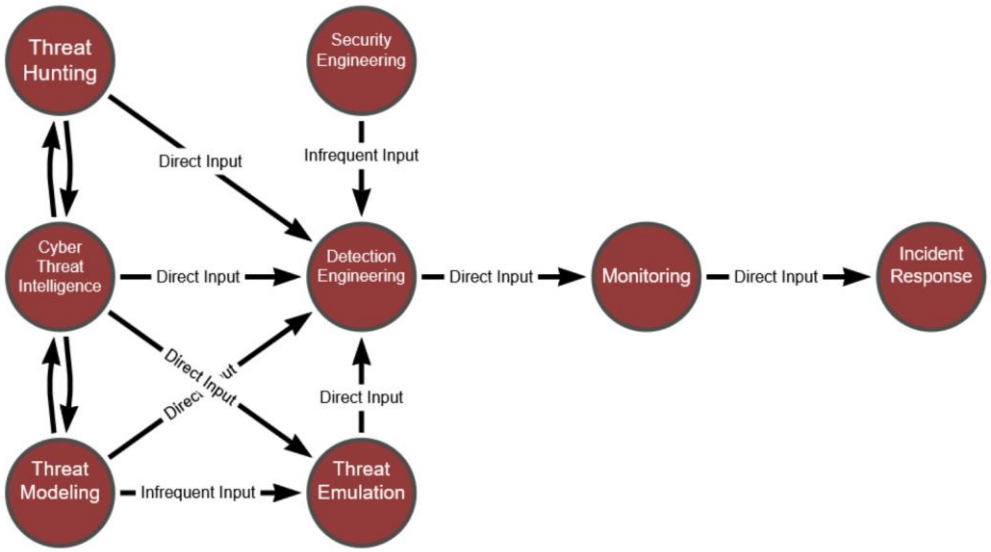
- Fastest way to **turn threat intel into detections** and test your resilience against relevant threats
  - Effectively use internal SME knowledge about infrastructure, systems, apps, critical assets
- Validate internal and external security controls
  - Your own, but also MSSP/provider/partner stacks
- **Rapid testing and reporting**
  - No need for external testers and large reports that takes weeks to write
  - Campaign/Assessment result presentation
  - Report directly in Jira, Trello, Monday, Asana +
- Build a repeatable and measurable **internal** process and **technique library**
- Impact on strategic security **decisions**, **budget**, sprint planning



What is Purple Teaming? - Edgewater Federal Solutions

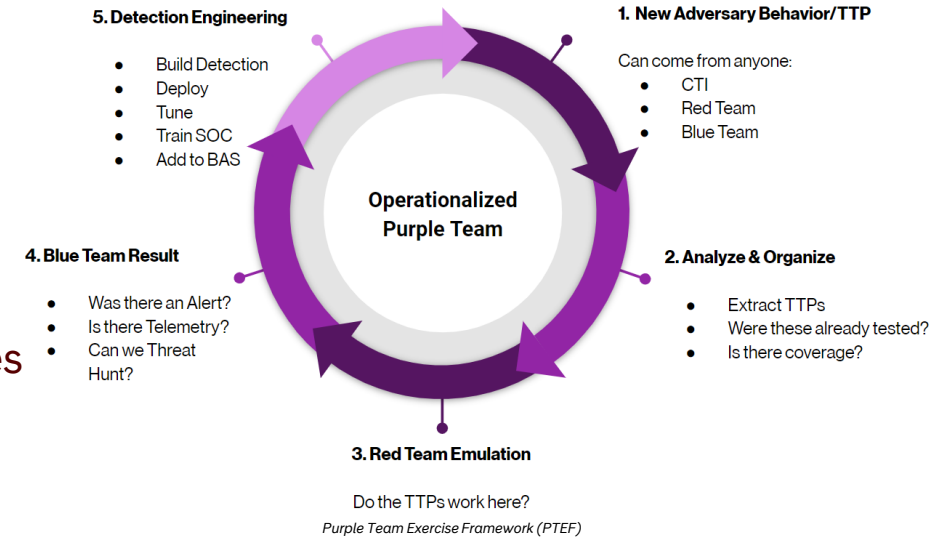
Purple Teaming in Storebrand

- Internal Purple Teaming / Threat Emulation initiative by SecOps (CDC)
- Campaigns and atomic tests based on relevant, vetted Threat Intelligence
  - **Quarterly TI report -> Quarterly PT**
- Goal is to utilize internal knowledge, threat intelligence and capabilities for continuous threat informed testing
  - Think TIBER and DORA TLPT; but at a smaller scale, more refined, internally informed and prioritized based on new relevant TI
- **Closely tied to Detection Engineering**
  - Threat emulation using atomic testing is already a key piece of the DE process during prototyping and **validation**



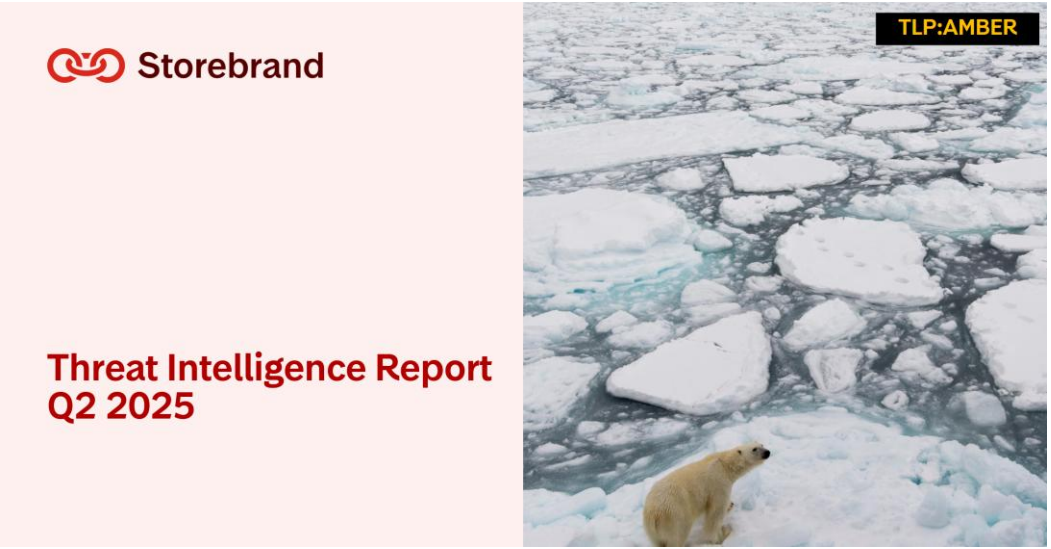
Why we do Purple Teaming?

- Simulate relevant threat actors targeting Storebrand
- Uncover detection gaps and misconfigurations
- Assess parts of Storebrand not necessarily covered, or missed, during routine external pentests, TIBER and red teaming
- Improve detection and response capabilities
  - Familiarize different teams with relevant threats and TTPs
  - Inside and outside of the "security sphere"
- Increase security awareness and mindset
- Improve detection coverage



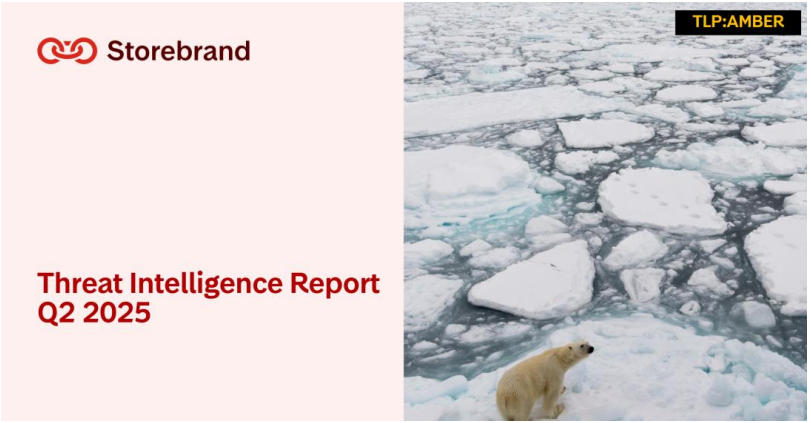
How are we doing PTs?

- Quarterly Purple Team Campaigns based on the quarterly internal STB Threat Intelligence Report
- Interpret TI reports
  - Extract adversary behavior and TTPs
  - Relevancy, applicability and realism

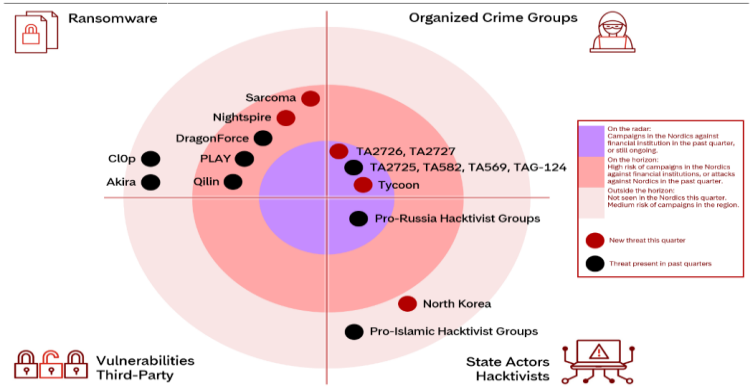


How are we doing PTs?

- A draft campaign is created
  - Submit RFI if needed
- Draft is presented to TI
  - **PT meets with TI**
  - TI approves/denies/comes with suggestions
- TI approved draft is presented to SecOps Management
  - **PT meets with MGMT**
  - Approves/denies/requests changes/suggestions
- Relevant stakeholders are informed/involved
- Get proper sign-off and approval before starting



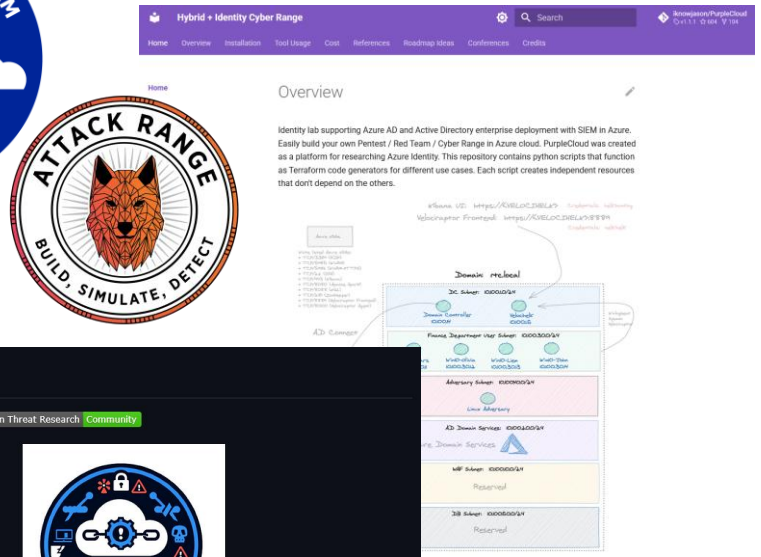
Threat Radar

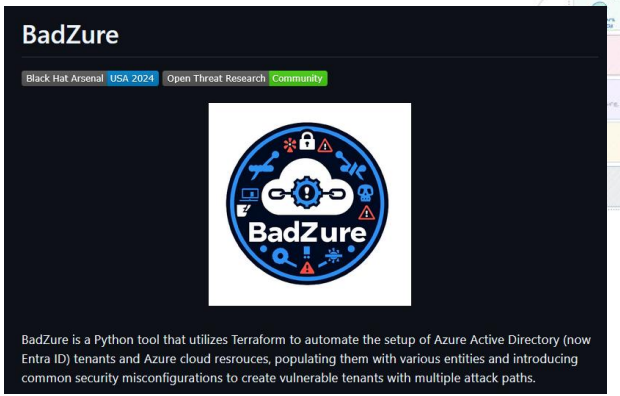


Q2 Threat Radar from Q2 TI report.

What are the capability requirements?

- Offensive knowledge
  - CNO, OPSEC, Malware Development, DevOps (attacker infrastructure, automation, IaC) AI usage, MCPs
- Defensive knowledge
  - Blue team needs to be capable with the security stack, SIEM, query language, DEATH, response, playbooks
- Logs, telemetry and collection pipeline
- Campaign logging, tracking , reporting and documentation
  - **NEEDS** to be a part of existing processes and workflows within your organization
- Infrastructure
  - Infrastructure to host and stage OST, payloads, C2 servers, BAS tools, mail servers for offense
    - You don't need expensive frameworks or tools to get going
    - Atomic Red Team, Stratus Red Team
  - Purple team lab/tenant/environment
    - Ludus, Purple Cloud, BadZure, Splunk Attack Range
  - Accounts with commonly seen services used by threat actors
  - Laptops and/or AVDs for testing
  - Clearly identifiable test users
  - **BUT ALSO** - Realistic identities (test users that functions like real users, licensed and i.e. provisioned Workday -> Entra ID)





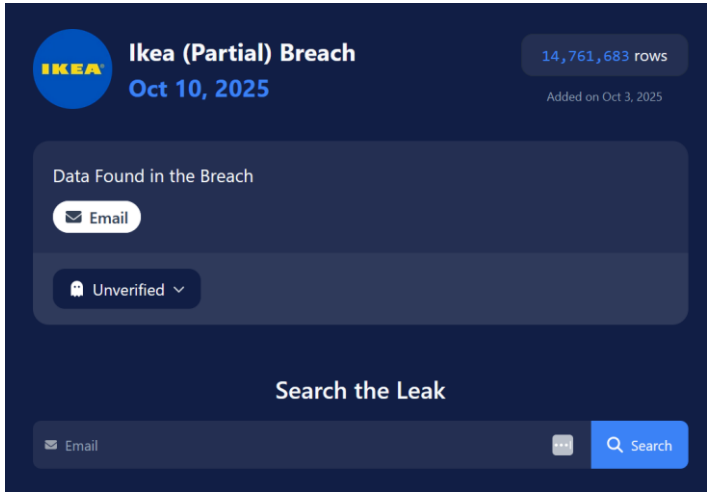
Campaign overview

- Purple Team Campaign based on internal "Threat Intelligence Report - 2025 Q2"
- SVG smuggling
- ClickFix, FileFix, DownloadFix, TerminalFix
- Malicious use of AI
  - Obtain capabilities
    - https://attack.mitre.org/techniques/T1588/007/
  - Phishing
- Salesforce
  - Requested by management due to high relevancy in Storebrand
  - Ongoing campaigns against large international organizations
  - Nordic targets
  - Local front-page news
  - Added as a "Post Exploitation Scenario"
- Campaign documented in wiki

Companies Impacted

The ShinyHunters leak site lists **39 companies**. Some of the most notable include:

- **Google** – confirmed exposure of Salesforce data tied to small business partners.
- **Chanel** – admitted its U.S. customer database was compromised.
- Other names include **Adidas, Louis Vuitton, Cisco, Qantas, Allianz Life, Disney, Ikea, and McDonald's**.



Threat (Sim)Emulation Plan

- TI must be actionable and relevant
  - Can activity be tied to your organization/sector/vertical/CERT members?
  - Extract TTPs
    - ATT&CK mapped TTPs
    - Note down unmapped behaviors
    - Can you map it yourself?
    - Insider Threat Matrix, SaaS Attacks Matrix
  - What behavior/TTPs are likely to repeat?
  - What got them caught?
    - OPSEC mistakes
  - What's unique with TA/campaign vs overlap with prior reports?
  - Prefer high-signal/fidelity TTPs/behavior
  - Exposure points vs shiny new TTP

David Bertho 14.10. 11:54

Hi!
We are trying to make the GTL report useful for more than TIBER. As the chief threat emulation and detection officer, you are the prime audience for what we are trying to achieve
Do you have ideas on things we should improve to make it useful for you?
Do you need me to set up a meeting or something else to make sure that doesnt end up in the bin like other misc todos?

14.10. 12:17 Edited

> David Bertho 14.10.2025 11:54
> Hi! We are trying to make the GTL report useful for more than TIBER. As the chief threat emulation and detection officer, you are the prim...

Hola!

Any information you can include that makes the TI consumption, detection decisions and prioritization easier and more streamlined, consumable and actionable. Generally speaking, what I feel helps the most is specifics, both with operational and consumable intel. Which could be:

- How does TA activity relate to us/NFCERT members
- What industry specific tools or processes are being targeted
  - Salesforce, Bloomberg etc
- MITRE ATT&CK Mapping of TTPs
- TA specific behavior other than what can be mapped with ATT&CK
- Practical information on their MO
- Visual attack chains that show TTPs and behaviour
  - Helps identify technique dependencies
- Code snippets, examples, even samples if possible/responsible
- MITRE ATT&CK Navigator JSON that can be visualized using tools like https://jsoncrack.com

My desired outcome when reading TI reports is generally to try to answer:

- Can I identify behaviour, trends and techniques that the TA(s) are likely to employ again?
- How can I identify TA behaviour besides known (past) ATT&CK mapped TTPs?
- What was the TAs intended objective?
- How did they achieve the objective?
- What (opsec) mistakes were made by both TA and responders (if any)?
  - What got them caught?
    - Again circling back to behaviour, if they keep making repeat mistakes, reuse the same infrastructure, VPS/VPN hosts, UAs, redirs, compile from their personal machines etc.
    - Is it simply easier or more cost/time/resource efficient to detect or focus on what action/behaviour that got them caught vs the actual fancy new TTP they used?
- What steps could be taken to detect this activity in our environment?
  - Other than SIEM detections, what other tools could be used?
- Is there similarity or overlap in this report and previous reports?
  - Patterns that can be used to identify TA activity
- What behaviour is unique to this TA/campaign?
  - Behaviour that is difficult for the TA to change

Threat (Sim)Emulation Plan

Q2 Purple Team Campaign

By Eirik Sveen 7 min 12 Add a reaction Aura Table Filter

Quarterly Purple Team Campaigns are based on the quarterly internal STB Threat Intelligence Report, and will be designed, planned and ran as close to the release of the report as possible.

Campaign results are tracked in VECTR and Jira, and a report detailing the findings from each Scenario will be published under Reports when the campaign has concluded.

Description

Purple Team Campaign based on the Threat Intelligence Report - 2025 Q2.
Plan and implement campaign from a TI vs practicality POV:

- High level overview
- Kill chain
- TTPs
- Atomic testing vs end-to-end Scenario based test (Atomic tests probably best for first iteration)
- What is sufficient to prove impact
- RT Preparation steps (scripts, payloads, delivery)
- BT Preparation steps (anything missing that we know of that would impact results/logging, ingestion, detection, alerting, do we have everything in place to detect and alert on the proposed Kill chain and TTPs)
- Infrastructure (VECTR, C2, redir, BallisKit, misc)

Malicious use of AI (Generate needed phishing material, landing page, attachments)
AiTM (MS phishing, simulate Tycoon)
SVG attachments (run/drop payload)
ClickFix, fake CAPTHCA (make a custom CAPTHCA page using AI)
Use legitimate infrastructure for malicious purposes (Azure, Cloudflare/front, GCP, AWS)

Threat Emulation Plan - Q2 2025 Campaign

1. High-level overview (TI → practicality)

Goal:
Validate and improve Storebrand's ability to prevent, detect, and respond to the most commonly seen and reported threats against Storebrand and other members of NFCERT, such as AiTM Microsoft phishing, malicious SVG attachments, and ClickFix/Fake CAPTCHA social engineering attacks resulting in malware execution on endpoints, plus adversaries "living off trusted sites", CDN abuse and malicious use of generative AI to streamline and speed up their campaigns.

Why:

- AiTM campaigns against Microsoft accounts are expected to persist and are commonly delivered via modern phishing kits (i.e. Tycoon).
- SVG attachments surged in March–April 2025 and were clicked by employees (no impact observed), a clear awareness and control gap to validate.
- ClickFix is the most commonly used attack vector against Nordic financials in 2025 and is now used by multiple state actors.
- Threat actors frequently abuse legitimate infrastructure (Cloudflare/CAPTCHA services, compromised WordPress, linkin.bio redirecting to wpenginepowered.com) to bypass email defenses.

Output:

- Confirm that current controls (web, identity, endpoint, cloud) can detect, alert, and contain these singular and chained atomic tests.
  - Chained atomics with supplemental user behaviour (assisted clicks) in this case.
- Produce concrete tuning backlogs for detections, controls, and input for user facing training and awareness that can be shared with second line/GRC.
- Establish repeatable atomic tests for quarterly purple team campaigns and ad hoc validation, then proceed to longer/broader scenario based tests.
  - I.e. Q3 Purple Team Campaign

Threat (Sim)Emulation Plan

MITRE ATT&CK Mapping

Resource Development

- T1588.007 Obtain Capabilities: Artificial Intelligence (Malicious use of generative AI)

Initial Access / Delivery

- T1566.002 Spearphishing Link (ClickFix, SVG)
- T1566.001 Spearphishing Attachment (SVG)
- T1027.017 Obfuscated Files or Information: SVG Smuggling
- T1204 User Execution (Simulated social engineering through assisted clicks)
- T1059 Command and Scripting Interpreter
- T1059.009 Command and Scripting Interpreter: Cloud API
- T1036 Masquerading (Fake CAPTCHA)

Credential / Session Theft / Persistence

- T1539 Steal Web Session Cookie (AiTM session replay simulation)
- T1098.001 Additional Cloud Credentials
- T1671 Cloud Application Integration
- T1110.004 Credential Stuffing
- T1656 Impersonation

Command & Control / Execution / Lateral Movement

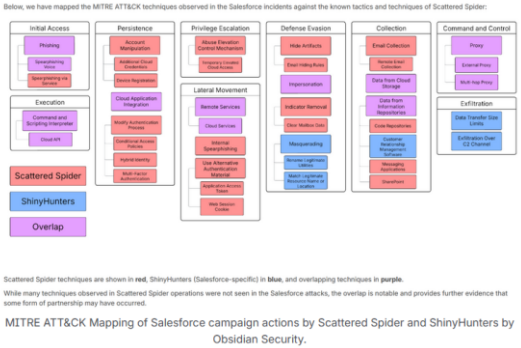
- User Execution: Malicious Copy and Paste (ClickFix used to run `.scr`, `.exe`, `.pif`, `.cpl`, etc)
- T1059.001 PowerShell (PowerShell spawned from Click)
- T1090 Proxy (Redir/CDN/fronting)
- T1105 Ingress Tool Transfer
- T1021.007 Remote Services: Cloud Services

Collection / Exfiltration

- T1530 Data from Cloud Storage
- T1213 Data from Information Repositories
- T1213.004 Data from Information Repositories: Customer Relationship Management Software

Resource/Infra Abuse

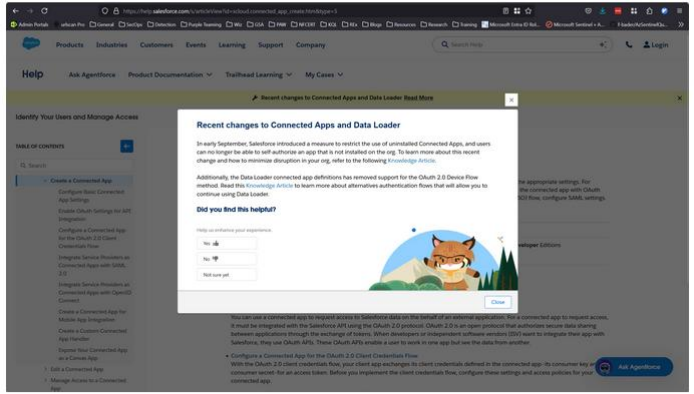
- T1583 Acquire Infrastructure (cloud/CDN/domains),
- T1584 Compromise Infrastructure (compromised WP sites as delivery)



MITRE ATT&CK Mapping of Salesforce campaign actions by Scattered Spider and ShinyHunters by Obsidian Security.

Additional TI provided via RFI here: SECTASK-807: Request for Threat Intelligence DONE

These attacks have primarily been using Salesforce Connected Apps and their device code flow during social engineering of users, to trick regular and admin users into connecting a malicious app to their Salesforce tenant. This has been partially fixed by Salesforce, as it is no longer possible to accept/onboard non-preapproved Connected Apps.



It is however still possible to simulate past and likely adapted attacks, like using Salesloft or other applications that interface with Salesforce through the API, by obtaining a Salesforce admins cookies/credentials through phishing, and abusing these using SSO or the Salesforce API directly.

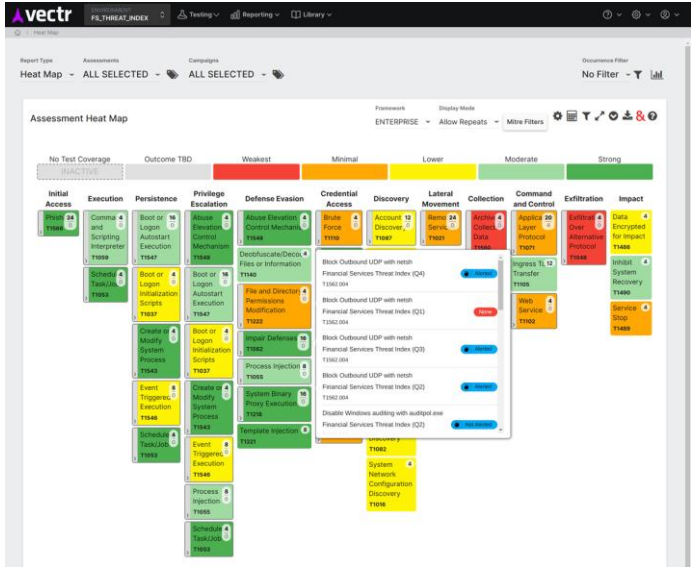
Below are known previously used User-Agent Strings that can be used during simulation:

User-Agent Strings:
Salesforce-Multi-Org-Fetcher/1.0
Salesforce-CLI/1.0
python-requests/2.32.4
Python/3.11 aiohttp/3.12.15

These UA's can be used/replaced/spoofed directly or via Burp, when interacting with the Salesforce API. The Salesforce API python library can be found here: salesforce-api .

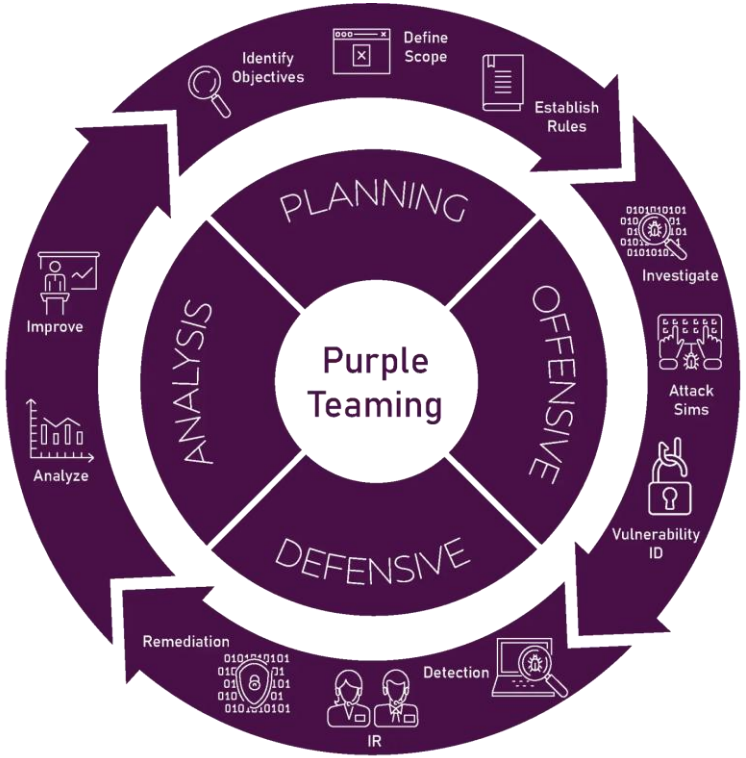
Reporting, Tracking and Documentation

- VECTR for logging Campaigns and Assessments
  - **Full transparency between red and blue**
  - Red team actions, test cases, operator guidance, commands, test cases mapped to ATT&CK
  - Blue team response and detection, alerted/blocked/logged, evidence
  - **Track and report coverage over time**
  - Import STIX2 data
    - MITRE ATT&CK v18 👀
  - Does the heavy lifting with creating timelines, graphs, heat maps, pie charts, resilience trends
  - **ATTiRe Structured Logging Format**
    - Export from Atomic Red Team, custom tests, MCPs
  - VECTR Execution Framework
    - Build individual test cases or entire campaigns as an executable
- **Different audiences**
  - SOC, DE wants tactical info, timeline, exact commands, artifacts, queries
  - Technical management wants operational info, scenario, timeline, telemetry/alert coverage, identified gaps
  - Middle management, C-level and boards are usually looking for high level scenario, resilience, risk and comparison to industry and peers
- **Tracking, reporting and documentation in Jira and/or Confluence**
  - Depending on target audience, tickets to report individual findings and delegate and track remediation tasks
  - Everything is already documented and filled out in VECTR
    - CTRL + C -> CTRL + V, include proof (logs, commands ran, screenshots)
    - Remediation guidance, links to documentation etc.
    - **NEVER assume the recipient is an expert in offensive or defensive aspects**
      - Tailor language to the target audience



Progress, Continuous Improvement and KPIs

- Where we are today
  - Defined and documented Purple Team Framework
  - Processes that aligns with the larger organization
  - Dedicated testing infrastructure, realistic identities
  - VECTR in AKS cluster
  - Detection-as-Code Pipeline
- Continuous Improvement
  - TI-based ad hoc atomic testing
    - PT <-> DE
  - Atomic library
    - Allows for rapid re-runs and validation
    - Little to non offensive knowledge required
  - Reporting and presentation to stakeholders
- KPIs
  - Resilience (% of test cases alerted on, tactic/platform)
  - Time (Time to detect, contain, mitigate)
    - Individually by atomic or campaign
  - Output (number of new detection, number of gaps closed by defensive tool/source)
  - Precision (alert precision, FP rates, tolerance TI-weighted by top risks)
  - DO NOT overfocus on
    - **Total number of tests, alerts, tickets created**
    - **"100% coverage"**
    - **Generic MTTD**
  - Track detections before/after each leg-up/shortcut to keep TTD, TTR, MTTD, MTTR honest
- **JUST GET STARTED!** 💜🚀



What is Detection Engineering?

- "The discipline of systematically designing, building, testing, and maintaining threat detections that reliably identify adversary behaviors in production environments"
- Turning threat intelligence, hunt findings, and incident lessons into validated detection logic
- Engineering discipline, not ad-hoc rule writing, version control, peer review, testing, documentation, deployment pipelines
- Two complementary approaches
  - **Coverage-driven** approach, map detections to MITRE ATT&CK, identify gaps, prioritize based on threat relevance to your organization
  - **Event-driven** approach, new threat reports, incidents, or purple team findings generate detection backlog items
- Overlaps with purple teaming on validation, tests produce true positives that prove detections work
- Typical focus areas
  - Write detection logic (KQL, Sigma, SPL) against real telemetry, not theoretical data
  - Document every detection, goal, blind spots, false positives, response steps, validation evidence
  - Tune continuously, measure TP/FP rates, refactor or retire detections that produce noise
    - Noise VS benefit
  - Automate the lifecycle, CI/CD from code to deployed analytics rule, with query linting/validation, format conversion and constraint validation

1. Storebrand Detection Engineering Framework

By Eirik Sveen | 9 min | 17 | Add a reaction | Aura Table Filter

Introduction to the Detection Engineering Framework

The Storebrand Detection Engineering Framework aims to provide a structured and detailed approach for developing, testing, deploying and maintaining detection logic, from targeted atomics to high-fidelity alerts.

It integrates methodologies and tools such as SpecterOps' Funnel of Fidelity, Detection Spectrum and Input-Based Prioritization Model, Palantir's Alerting and Detection Strategy (ADS) and Elastic's Detection Engineering Behavior Maturity Model (DEBMM) ensuring that all detection efforts are aligned with Storebrand's security priorities, threat modelling and real-world threats to the financial sector, and that there is a clear continuous improvement process and method of measuring detection maturity.

The framework is designed to guide Storebrand's detection engineers through each step of the detection engineering lifecycle, from input and prioritization to research and hypothesis formulation, prototyping, testing, deployment and continuous improvement.

Detection Engineering

Detection engineering is a systematic, threat informed process of creating and refining rules that turn raw telemetry data into actionable security alerts. Detection Engineers use the framework to identify the most critical attack techniques based on risk, prioritize detections, and integrate them into Storebrand's security information and event management (SIEM) systems (Sentinel, XDR and other application or platform specific SIEMs) systems and workflows. This ensures that detections are

Project Tenchigan (天地眼) LOCAL | Investigator | Thrunter | MCP | Replaying | Round 1 / 10 | Sessions | Import | Export | Replaying... | Reset

5	6	0	0	0	Hunt
AGENTS ACTIVE	KQL QUERIES	FINDINGS	HIGH CREDIBILITY	TIMELINE EVENTS	CURRENT PHASE

AGENTS

5 ACTIVE

H Hunt Director — running
Hunt Orchestrator

Selecting experts. Federation abuse requires deep identity knowledge + cross-cloud visibility.

DOMAIN EXPERTS

R Threat Researcher — done
Threat Research

TTP reference compiled. Key detection surfaces: AuditLogs (Set federation settings), AADSignInEventsBeta (SAML anomalies), Key Vault audit.

E Entra ID — running
Identity & Auth Expert

Querying for anomalous SAML token issuance patterns...

```
AADSignInEventsBeta | where Timestamp >
ago(14d) | where ApplicationId ≠ '' |
```

D Defender — running
Device Telemetry Expert

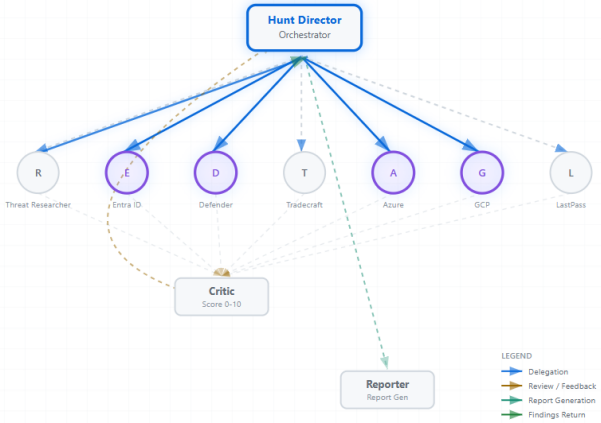
Hunting for PowerShell federation tooling and certificate export commands...

```
DeviceProcessEvents | where Timestamp >
ago(7d) | where FileName in~ ('powershe
```

T Tradecraft — idle

Scope | Hunt Round 1 | Pivot | Conclude

SCOPE → HUNT → PIVOT → CONCLUDE



AGENT WORKFLOW | ATTACK CHAIN | GEO MAP | ACTIVITY FEED 10 EVENTS | ↑ NEWEST

14:14:22 FINDING Threat Researcher → Director

TTP Reference:
1. **Golden SAML** (T1484.002): Attacker steals ADFS token-signing certificate, mints arbitrary SAML tokens. Detection: unusual federation domain changes, SAML assertions with unexpected claims, certificate access in Key Vault.
2. **Observable events**: 'Set domain authentication' (Entra AuditLogs), 'Update domain' operations, new signing certificate uploads.
3. **Tools**: AADInternals (Export-AADIntADFSSigningCertificate), ADFSDump, TokenTacticsV2. All leave PowerShell process telemetry.
4. **Known actors**: Midnight Blizzard (SolarWinds, 2020-2023), Storm-0558 (2023 key theft). Both targeted federation trust for persistence after initial cloud token theft.

▲ less

14:14:18 DELEGATE Director → Defender

Hunt for federation tooling on endpoints:

FINDINGS

0 FI

Findings will appear here as experts report investigation results

INVESTIGATION TIMELINE

0

Chronological timeline of correlated events from the investigation

Project Tenchigan (天地眼) LOCAL | Investigator | Thrunter | MCP ●●● | Paused | Round 1 / 10 | Sessions | Import | Export | Paused | Reset

1	6	9	9	1	Hunt
AGENTS ACTIVE	KQL QUERIES	FINDINGS	HIGH CREDIBILITY	TIMELINE EVENTS	CURRENT PHASE

AGENTS

1 ACTIVE

H Hunt Director
Hunt Orchestrator — running

Selecting experts. Federation abuse requires deep identity knowledge + cross-cloud visibility.

MESSAGES (16)

- ↓ 14:15:53 Review complete. Major hunt hit confirmed. Attack chain is coherent and follows classic Golden SAML persistence pattern ...
- ↑ 14:14:44 Review 11 findings + TTP research from Hunt Round 1. This hunt has produced significant hits. Assess attack chain cohere...
- ↓ 14:14:40 HUNT HIT - 2 findings:1. AADInternals detected: On device YOURDESK-IT42 (assigned to admin-ops), PowerShell executed: In...
- ↓ 14:14:38 HUNT HIT - 3 findings:1. Workload Identity Pool created: 'azure-

DOMAIN EXPERTS

R Threat Researcher
Threat Research — done

TTP reference compiled. Key detection surfaces: AuditLogs (Set federation settings), AADSignInEventsBeta (SAML anomalies), Key Vault audit.

Golden SAML and Silver SAML at...

STATUS CHANGES (3)

14:14:21 done TTP reference compiled. Key detection surfaces: AuditLogs (Set federation

Scope | Hunt Round 1 | Pivot | Conclude

AGENT WORKFLOW | ATTACK CHAIN | GEO MAP | ACTIVITY FEED 16 EVENTS | ↑ NEWEST

14:15:53	REVIEW	Critic → Director	**Review complete. Major hunt hit confirmed.** Attack chain is coherent and follows classic Golden SAML persistence pattern (Midnight Blizzard playbook). Timeline: Token theft → Key Vault cert extraction → AADInternals on admin workstation → Federated domain creation → Cross-cloud ▾ show more
14:14:44	REVIEW	Director → Critic	Review **11 findings + TTP research** from Hunt Round 1. This hunt has produced significant hits. Assess attack chain coherence and identify gaps requiring deeper investigation.
14:14:40	FINDING	Defender → Director	**HUNT HIT - 2 findings:** 1. **AADInternals detected**: On device YOURDESK-IT42 (assigned to admin-ops), PowerShell executed: Install-Module AADInternals; Import-Module AADInternals; Export- ▾ show more
14:14:38	FINDING	GCP → Director	**HUNT HIT - 3 findings:**

FINDINGS

9 FINDI

DEF-102 Certificate exported and exfiltrated from endpoint — 9
ADFS token-signing certificate exported to C:\Temp\ts.pf via Export-PfxCertificate, then uploaded to external endpoint. Malicious scheduled task 'WindowsUpdateCheck' created on same day as persistence mechanism for tooling execution.
Defender — verifie

DEF-101 AADInternals executed on admin workstation YOURDESK-IT42 — 10
AADInternals module installed and executed on YOURDESK-IT42 (admin-ops device) at 2026-02-14 22:05 UTC. Export-AADIntADFSSigningCertificate cmdlet used extract token-signing certificate. Execution chained from malicious scheduled task 'WindowsUpdateCheck'.
Defender — verifie

GCP-102 8.7GB data staged in GCP bucket asia-southeast1 — 9
GCP — verifie

GCP-101 Workload Identity Pool trusting rogue Entra ID federation — 10
GCP — verifie

AZ-102 Data staging in Southeast Asia storage account — 9
Azure — verifie

Project Tenchigan (天地眼) LOCAL

Investigator | Thrunter

MCP ● ● ● Paused Round 1 / 10 Sessions Import Export Paused Reset

AGENTS

1 ACTIVE

Hunt Director

Hunt Orchestrator — running

Selecting experts. Federation abuse requires deep identity knowledge + cross-cloud visibility.

MESSAGES (16)

- ↓ 14:15:53 Review complete. Major hunt hit confirmed. Attack chain is coherent and follows classic Golden SAML persistence pattern ...
- ↑ 14:14:44 Review 11 findings + TTP research from Hunt Round 1. This hunt has produced significant hits. Assess attack chain cohere...
- ↓ 14:14:40 HUNT HIT - 2 findings:1. AADInternals detected: On device YOURDESK-IT42 (assigned to admin-ops), PowerShell executed: In...
- ↓ 14:14:38 HUNT HIT - 3 findings:1. Workload Identity Pool created: 'azure-

DOMAIN EXPERTS

Threat Researcher

Threat Research — done

TTP reference compiled. Key detection surfaces: AuditLogs (Set federation settings), AADSignInEventsBeta (SAML anomalies), Key Vault audit.

FINDINGS (1)

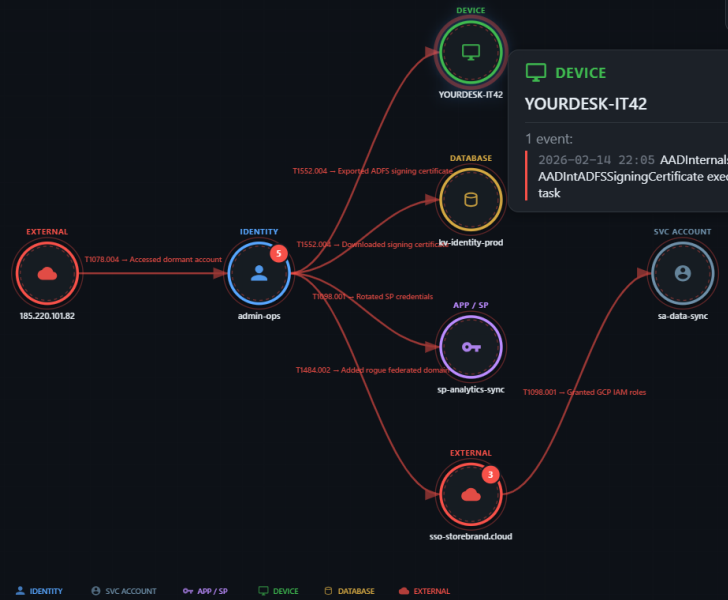
- 9 TTP Profile: Golden SAML with cross-cloud pivot

MESSAGES (2)

- ↑ 14:14:22 TTP Reference:1. Golden SAML (T1484.002): Attacker steals ADFS token-signing certificate, mints arbitrary SAML tokens. D...
- ↓ 14:14:14 Research federation trust

Scope | Hunt Round 1 | Pivot | Conclude

ATTACK CHAIN VISUALIZATION



DEVICE

YOURDESK-IT42

1 event:

2026-02-14 22:05 AADInternals installed and Export-AADIntADFSSigningCertificate executed on YOURDESK-IT42 via scheduled task

AGENT WORKFLOW | ATTACK CHAIN | GEO MAP | ACTIVITY FEED 16 EVENTS | ↑ NEWEST

14:15:53	REVIEW	Critic → Director	**Review complete. Major hunt hit confirmed.** Attack chain is coherent and follows classic Golden SAML persistence pattern (Midnight Blizzard playbook). Timeline: Token theft → Key Vault cert extraction → AADInternals on admin workstation → Federated domain creation → Cross-cloud ▾ show more
14:14:44	REVIEW	Director → Critic	Review **11 findings + TTP research** from Hunt Round 1. This hunt has produced significant hits. Assess attack chain coherence and identify gaps requiring deeper investigation.
14:14:40	FINDING	Defender → Director	**HUNT HIT - 2 findings:** 1. AADInternals detected: On device YOURDESK-IT42 (assigned to admin-ops), PowerShell

FINDINGS

9 FINDI

- DEF-102 Certificate exported and exfiltrated from endpoint — 9 — Defender — verifie
- .01 AADInternals executed on admin workstation YOURDESK-IT42 — 10 — nder — verifie
- GCP-102 8.7GB data staged in GCP bucket asia-southeast1 — 9 — GCP — verifie
- GCP-101 Workload Identity Pool trusting rogue Entra ID federation — 10 — GCP — verifie
- AZ-102 Data staging in Southeast Asia storage account — 9 — Azure — verifie
- AZ-101 ADFS token-signing certificate stolen from Key Vault — 10 — Azure — verifie
- ENT-102 Dormant admin-ops account reactivated from Tor — 9 — Entra ID — verifie
- ENT-101 Rogue federated domain sso-storebrand[.]cloud — 10 — Entra ID — verifie

Project Tenchigan (天地眼) LOCAL

Investigator | Thrunter

MCP ● ● ●

Idle Round 0 / 10

Sessions

0	0	0	0
AGENTS ACTIVE	KQL QUERIES	FINDINGS	HIGH CREDIBILITY

NTS 0 ACTIVE

Hunt Director
Hunt Orchestrator
idle

EXPERTS

Threat Researcher
Threat Research
idle

Entra ID
Identity & Auth Expert
idle

Defender
Device Telemetry Expert
idle

Tradecraft
IOC Correlation Expert
idle

Azure
Azure Activity Expert
idle

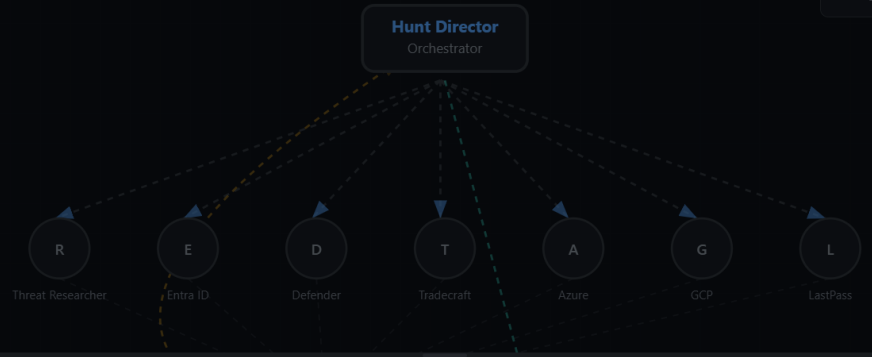
GCP
GCP Audit Expert
idle

LastPass
LastPass Audit Expert
idle

& REPORTING

Scope | Hunt | Pivot | Conclude

SCOPE → HUNT → PIVOT → CONCLUDE



AGENT WORKFLOW | ATTACK CHAIN | GEO MAP | ACTIVITY FEED 16 EVENTS

Sessions

0 sessions | Clear failed | ×

NEW SESSION

Investigation | Manual

Target (user, IP, device, technique...)

Depth (optional) | Create & Connect

Sign in with Microsoft | Refresh tokens (VS Code) | Authenticated

Manual token paste

Alternatively, paste bearer tokens from your VS Code MCP config or browser dev tools. Tokens are stored in browser session only.

AUTHORIZATION (JWT)

Bearer eyJ0 ...

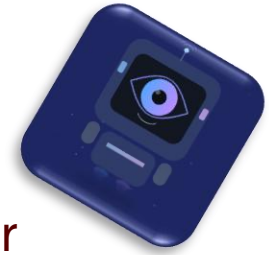
SCC AUTH TOKEN (OPTIONAL)

Bearer UBSAy ... (optional)

Save Tokens | Clear

No sessions yet. Create one above.

Tenchigan



- Start new investigations, hunts or delegate detection engineering work from Slack
  - Threat and context aware
  - Extracts relevant parts of messages and replies
  - Cuts filler to preserve context and tokens
  - Reports back high credibility findings (score >= 7) and final verdict
- Jira integration for posting findings as comments to Incident or Hunt tickets
- Submits WIP detection rules to DaC repository

Storebrand

Invester i fremtiden

@0xSV1 / eirik.sveen@storebrand.no / linkedin.com/in/eirik-sveen